"CIA", Threats, and Ethics

In order for the users of this labware gain a better understanding of mobile security, in this section, we will give a brief introduction to the concepts and ethics related to mobile security.

The Concept of "CIA"

When talking about security, people always mention the notion of the so-called "CIA". Here, "C" represents "Confidentiality", "I" represents "Integrity" and "A" represents "Availability". These three elements are three significant concepts standing out when we deal with information security. Private information will be secured when these three requirements are met. Let's look at each of these concepts.

- **Confidentiality:** "Confidentiality refers to limiting information access and disclosure to authorized users -- the right people -- and preventing access by or disclosure to unauthorized ones -- the wrong people" [1]. In Oxford Dictionaries, confidentiality means "indicating that what one says is private or secret" [2]. The meaning of the confidentiality reflects the basic concept of security which is to protect private or secret information from obtaining by unwanted people. It also means that the information is not spread widely among people. Confidentiality also expresses an concept that those private or secret information should only be accessed by people with authorization to these information. This reveals what security does: to avoid information owned by some people from being obtained by people without permission to get access to that information. From the meaning of confidentiality, there are two important issues declared: the ownership of the information we are protecting, and the accessibility of the information which we want to secure. There are several aspects of confidentiality in the society, such as: business confidentiality and home confidentiality. Both business confidentiality and home confidentiality seek to protect financial data; both of them seek to protect account numbers; and both of them seek to protect personal information. The only real difference is that the business confidentiality emphasizes on protecting the product data or strategic intentions in order to remain competitive in the marketplace. To ensure confidentiality, we have already got some methods, for example, authentication methods like user-IDs and passwords, that uniquely identify data systems' users and access controls to the resources of the data systems.
- **Integrity:** Integrity generally reflects the trustworthiness of information resources. Integrity can be divided in two aspects, the personality "of being honest and having strong moral principles" and for data resources it means "the state of being whole and undivided"[2]. The first part means that people should keep honest and have strong moral principles. They need to decline to do any actions that may have bad effects on secured information or may cause significant dangers, and they have to enter the information reflecting actual circumstances. The second part of meaning conveys a concept that when we deal with security issues for some information, we have to ensure all the parts are integrated into a whole, and there are no parts missing. It also means that we have to keep the integrity of security. In order to maintain integrity of information, many businesses employ electronic protections or two person integrity for decision making (checks and balances).
- **Availability[3]:** Availability means "assuring information and communications services will be ready for use when expected". Hackers could attack or spread virus at any time. As a result, the most important and simply understood thing is that we have to keep our security mechanism work while there are someone attacking our system or some virus destroying our system. If we cannot make sure the availability of our security system, whatever we do is in vain. Availability could be affected by a lot of incidents, like technical problem, human being mistakes, or electricity problem.

Figure.1 shows the relationship between the information to be secured and the "CIA".

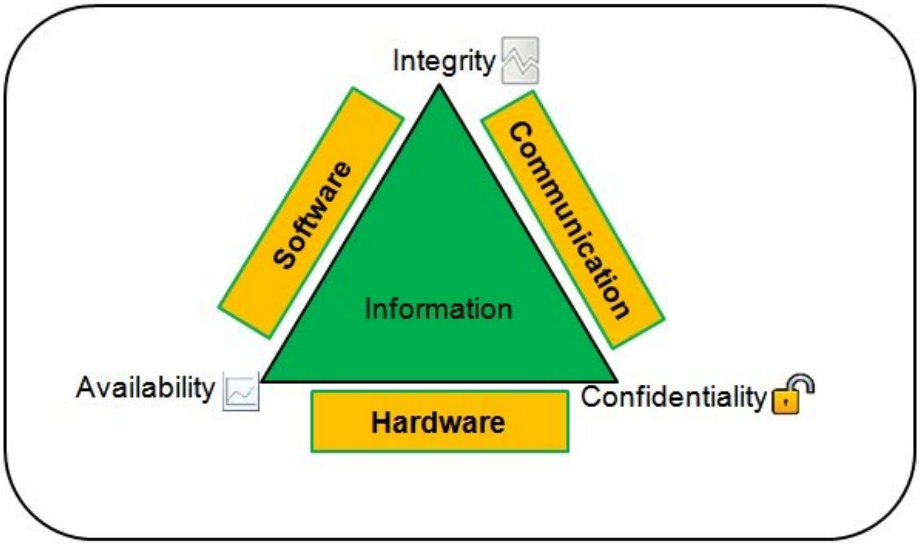


Figure.1 CIA Diagram

Cyber Threats & Mobile Threats

"CIA" has the ability to ensure the security of information. Breaking "CIA" may cause cyber threats. For mobile security, it will cause mobile threats. Now, let's have a look at some existing cyber threats and mobile threats.

In past ten years, there are lots of changes on our working environment. One of the biggest change is that our important working infomation can no longer only be leaven in our office, it can now be transmitted to employees' lapstops and smart phones. Ten years ago, few employees could work at home or on the road, but as with the mobile technology's improvements all these circumstances have come true. Even though such improvement makes our life and work easier, the information that we produce and we work with faces with more and more threats. Mobile threats can be categorized into two main segments:**Malicious activity by attackers** and **Vulnerabilities.**

- **Malicious Activity by Attackers[5]:**
  In these cases attackers use different tricks to entice a victim to install a Trojan Application. The innocent users think they are installing a game or utility but instead they get a hidden spyware, phishing UI, or unauthorized premium dialing. Some of the attack vectors fall in this category are:
  - **1. Activity Monitoring and Data Retrieval**
    Spywares are best known for these kinds of activities. Data which is being generated on the device can be intercepted in real time for example redirecting emails to a hidden third party address, letting an attacker hear about phone calls or simply open microphone recording. Stored data such as a contact list or saved email messages can also be retrieved.
    2. Unauthorized dialing, SMS, and Payments
    Criminals seeking to monetize weaknesses in human nature and the mobile app distribution model can turn to premium rate phone calls and premium rate SMS messages. By including premium dialing functionality into a Trojan app the attacker can run up the victim's phone bill and get the mobile carriers to collect and distribute the money to them. Mobile devices can also be used to purchase items, real and virtual, and have the cost billed on the customer's mobile bill. Another use of unauthorized SMS text message is as a spreading vector for worms. Once a device is infected a worm it can send SMS text messages to all contacts in the address book with a link to trick the recipient to download and install the worm.
    3. Unauthorized Network Connectivity (Exfiltration or Command & Control)
    Spyware or other malicious application typically require exfiltration to be of benefit to the attacker. Since mobile devices are designed for communication, there are many potential vectors that a malicious app can use to send data to the attacker. A full functioned malicious program will often allow the attacker to direct commands to the spyware to, for instance, turn on the microphone or grab a data file at a particular time.
    4. UI Impersonation
    Phishing attacks on PCs work by tricking the user to click on a link in their browser which brings them to a bogus website impersonating the UI of their bank or online service. The UI asks the user to enter in their credentials. The

attacker collects the credentials and uses them to impersonate the victim. On the mobile device there are new opportunities for attackers to perform UI impersonation. This can take the form of a web view application which presents a native mobile UI as a proxy to a native web app. With this attack, the user thinks they are downloading a legitimate app, such as a banking app, but instead they are getting an imposter that proxies information to the bank's genuine website. When the user authenticates themselves, they end up with sending their credentials to the attacker. Another vector for impersonation is a malicious app popping up a UI that impersonates the phone's native UI or the UI of a legitimate application. The victim is asked to authenticate and ends up sending their credentials to an attacker.

5. System Modification (Rootkit, APN Proxy Config)

Malicious applications will often attempt to modify the system configuration to hide their presence. This is often called rootkit behavior. Configuration changes also make certain attacks possible. An example is modifying the device proxy configuration or APN (Access Point Name).

6. Logic or Time bomb

Logic or time bombs are classic backdoor techniques that trigger malicious activity based on a specific event, device usage or time.

- **Vulnerabilities[5]:**

  The categories of vulnerabilities are errors in design or implementation that expose the mobile device data to interceptions by attackers. Vulnerabilities can also expose the mobile device or the cloud applications used from the device to unauthorized access. Some of the attack vectors which fall in this category are:

  - **1. Sensitive Data Leakage (Inadvertent or Side Channel)**

    Sensitive data leakage can be either inadvertent or side channel. A legitimate application's usage of device information and authentication methods can be poorly implemented thereby exposing the sensitive data to 3rd parties.

    2. Unsafe Sensitive Data Storage

    Mobile apps often store sensitive data such as banking and payment system PIN numbers, credit card numbers, or online service passwords. Sensitive data should always be stored encrypted so that attackers cannot simply retrieve this data from the file system. It should be noted that storing sensitive data without encryption on removable media such as a micro SD card is especially risky.

    3. Unsafe Sensitive Data Transmission

    It is important that sensitive data is encrypted in transmission in order not to be eavesdropped by attackers. Mobile devices are especially susceptible because they use wireless communications exclusively and often mobile devices have access to public WiFi, which is known to be insecure. SSL is one of the best ways to secure sensitive data in transit. If the application implements SSL it could still fall victim to a downgrade attack if it allows degrading HTTPS to HTTP. Another way SSL could be compromised is if the application does not fail on invalid certificates. This would enable that a man-in-the-middle attack.

    4. Hardcoded Password/Keys The usage of hardcoded passwords or keys is sometimes viewed as a shortcut by developers to make the application easier to implement, support, or debug. Once this hardcoded password is discovered through reverse engineering, it renders the security of the authenticated system since the application password is known by the hackers.

Figure.2 is a chart demonstrating mobile threats.

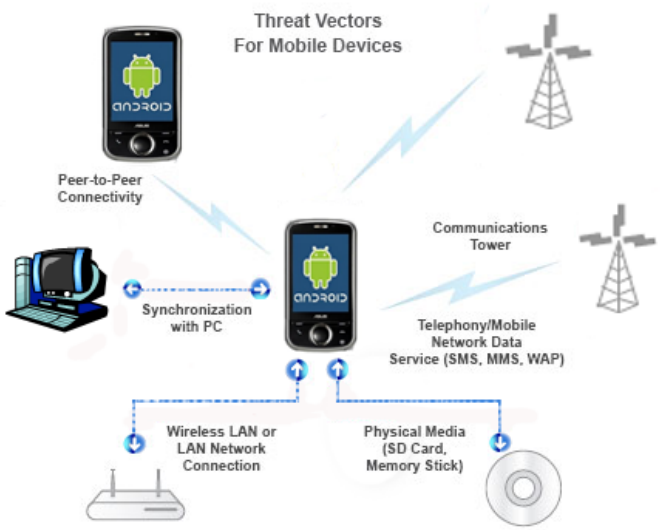


Figure. 2 Mobile Threats

Hacking Ethics

The mobile threats discussed above came to our real life because of unethical hackings from malicious hackers. In this last section, we will have a look at hacking ethics. The reason why it is important to know these hacking ethics is that these ethics are a good guide for us to distinguish between ethical hacking and unethical hacking.

- **Hacker ethic** is the generic phrase which describes the moral values and philosophy that are standard in the hacker community. The early hacker culture and resulting philosophy originated at the Massachusetts Institute of Technology (MIT) in the 1950s and 1960s. The guidelines of the hacker ethic make it easy to see how computers have evolved into the personal devices we know and rely upon today. The key points within this ethic are access, free information, and improvement to quality of life [6]. Ethics is about how we ought to live. The purpose of Ethics in Information Security is not just philosophically important, it can mean the survival of a business or an industry.
- **Ethical Challenges in Information Security [7]:**
    - Misrepresentation of certifications, skills
    - Abuse of privileges
    - Inappropriate monitoring
    - Withholding information
    - Divulging information inappropriately
    - Overstating issues
    - Conflicts of interest
    - Management / employee / client issues
- **The Original Hacker Ethic [8]:** The original Hacker Ethic was sort of an impromptu, informal ethical code developed by the original hackers of MIT and Stanford (SAIL) in the 50s and 60s. These "hackers" were the first generation of programmers, employing time-sharing terminal access to 'dumb' mainframes, and they often confronted various sorts of bureaucratic interference that prevented them from exploring fully how technological systems (computers, but also model trains, university steam tunnels, university phone systems, etc.) worked. The ethic reflects their resistance to these obstacles, and their ideology of the liberatory power of technology. The six principles of the Hacker Ethic are listed below, with some text samples showing where it appears within these documents.
    1. **Access to computers should be unlimited and total:** It is asserted to be a categorical imperative to remove any barriers between people and the use and understanding of any technology, no matter how large, complex, dangerous, labyrinthine, proprietary, or powerful.
    2. **All information should be free:** Free might mean without *restrictions* (freedom of movement = no censorship), without *control*(freedom of change/evolution = no ownership or authorship, no intellectual property), or without *monetary value* (no cost.) Some hackers even take this to mean information is alive, free to act on its own agency, as viruses, genetic algorithms, 'bots and other software programs do. Most hackers seem to advocate this principle in different senses of the word "free" at different times. In any case, when asked about the content of the Hacker Ethic, most people assert this as the key principle.

3. **Mistrust authority — promote decentralization:** Promote decentralization. This element of the ethic shows its strong anarchistic, individualistic, and libertarian nature. Hackers have always shown distrust toward large institutions, including but not limited to the State, corporations, and computer administrative bureaucracies (the IBM 'priesthood'). Tools like the PC are said to move power away from large organizations (who use mainframes) and put them in the hands of the 'little guy' user. Nowhere is this ethos stronger than among the anti-statist cypherpunks and extropians.
4. **Hackers should be judged by their hacking, not criteria such as degrees, age, race, sex, or position:** Nowhere is this ethos more apparent than in the strong embrace by most hackers of the levelling power of the Internet, where anonymity makes it possible for all such 'variables' about a person to remain unknown, and where their ideas must be judged on their merits alone since such contextual factors are not available.
5. **You can create art and beauty on a computer:** Hacking is equated with artistry and creativity. Furthermore, this element of the ethos raises it to the level of philosophy (as opposed to simple pragmatism), which (at least in some quarters) is about humanity's search for the good, the true, and the beautiful.
6. **Computers can change your life for the better:** In some ways, this last statement really is simply a corollary of the previous one. Since most of humanity desires things that are good, true, and/or beautiful, the fact that a computer can create such things would seem to mean that axiomatically it can change peoples' lives for the better. However, this is merely a declarative statement, which like the previous one reflects a deep-felt love of technology. It does not state explicitly that computers should always change peoples' lives for the better, or the principle that would follow from that, which is that it is unethical to use them to make peoples' lives worse.

- **Who is the Computer Underground? [8]:** The CU was referred as "90s hackers" or "new hackers," as opposed to old hackers, who are hackers (old sense of the term) from the 60s who subscribed to the original Hacker Ethic.

1. **Hackers** (Crackers, system intruders) - These are people who attempt to penetrate security systems on remote computers. This is the new sense of the term, whereas the old sense of the term simply referred to a person who was capable of creating hacks, or elegant, unusual, and unexpected uses of technology. Typical magazines (both print and online) read by hackers include *2600* and *Iron Feather Journal.*
2. **Phreaks** (Phone Phreakers, Blue Boxers) - These are people who attempt to use technology to explore and/or control the telephone system. Originally, this involved the use of "blue boxes" or tone generators, but as the phone company began using digital instead of electro-mechanical switches, the phreaks became more like hackers. Typical magazines read by Phreaks include *Phrack*, *Line Noize*, and *New Fone Express.*
3. **Virus writers** (also, creators of Trojans, worms, logic bombs) - These are people who write code which attempts to a) reproduce itself on other systems without authorization and b) often has a side effect, whether that be to display a message, play a prank, or trash a hard drive. Agents and spiders are essentially 'benevolent' virii, raising the question of how underground this activity really is. Typical magazines read by Virus writers include *40HEX.*
4. **Pirates** - Piracy is sort of a non-technical matter. Originally, it involved breaking copy protection on software, and this activity was called "cracking." Nowadays, few software vendors use copy protection, but there are still various minor measures used to prevent the unauthorized duplication of software. Pirates devote themselves to thwarting these things and sharing commercial software freely with their friends. They usually read *Pirate Newsletter* and *Pirate* magazine.
5. **Cypherpunks** (cryptoanarchists) - Cypherpunks freely distribute the tools and methods for making use of strong encryption, which is basically unbreakable except by massive supercomputers. Because the NSA and FBI cannot break strong encryption (which is the basis of the PGP or Pretty Good Privacy), programs that employ it are classified as munitions, and distribution of algorithms that make use of it is a felony. Some cryptoanarchists advocate strong encryption as a tool to completely evade the State, by preventing any access whatsoever to financial or personal information. They typically read the Cypherpunks mailing list.
6. **Anarchists** - are committed to distributing illegal (or at least morally suspect) information, including but not limited to data on bombmaking, lockpicking, pornography, drug manufacturing, pirate radio, and cable and satellite TV piracy. In this parlance of the computer underground, anarchists are less likely to advocate the overthrow of government than the simple refusal to obey restrictions on distributing information. They tend to read *Cult of the Dead Cow* (CDC) and *Activist Times Incorporated* (ATI).
7. **Cyberpunk** - usually some combination of the above, plus interest in technological self-modification, science fiction of the *Neuromancer* genre, and interest in hardware hacking and "street tech." A youth subculture in its own right, with some overlaps with the "modern primitive" and "raver" subcultures.

- **New Hacker Ethic [8]:** There is a new hacker ethic which 90s hackers live by. There are fragments of continuity from the old hacker ethic, as one can see. The new ethic appears to have developed like the old one, informally and by processes of mutual reinforcement.

1. **"Above all else, do no harm"** Do not damage computers or data if at all possible. Much like the key element of the Hippocratic Oath.
2. **Protect Privacy** People have a right to privacy, which means control over their own personal (or even familial) information. Privacy rights are notably missing from the U.S. Constitution, but they have been brought to the forefront of modern legal argument due to the growing surveillance power of technology. There still is no codified right to privacy for

U.S. citizens, although the Supreme Court has ruled that it is contained implicitly in its judgements legalizing the distribution of birth control and the right to first-trimester abortion.

3. **"Waste not, want not."** Computer resources should not lie idle and wasted. It's ethically wrong to keep people out of systems when they could be using them during idle time. This is what some people call the "joy riders' ethic." If you borrow someone's car, and return it with no damage, a full tank of gas, and perhaps even some suggestions for improved performance, have you not done them a favor? Especially if they never know you borrowed it in the first place for a few road trips? Isn't it wasting that precious engine power to leave the car in a parking spot while somebody else could be using it for a grocery trip? (Is it an ethical violation to borrow the car and make a set of keys for yourself so you can borrow it whenever you feel like? This is, after all, what most hackers do when they give themselves sysadmin privileges.) Yet most are possessive over the use of their own personal computer.
4. **Exceed Limitations** Hacking is about the continual transcendence of problem limitations. Some old hackers assert this principle, as an informal seventh addition to the original Ethic. Telling a hacker something can't be done, is a moral imperative for him to try. "Extropians" believe there is a universal force of expansion and growth, inverse to entropy, which they call "extropy." Hacking is seen as extropian because it always seeks to surpass current limits. Technology is seen as a necessarily exponential force of growth. Limitations must be overcome. For some hackers, these limitations might be unjust laws or outdated moral codes.
5. **The Communicational Imperative** People have the right to communicate and associate with their peers freely. The United Nations International Telecommunications Union (ITU) has stated in many conferences that this should be a fundamental human right, with which no nation should ever interfere. The sweeping freedoms given to amateur radio hobbyists internationally reflect this belief. Globally, it remains a significant moral problem, in that most developing nations lack the infrastructure to grant this right. Various UN reports have shown that despite the rhetoric, many Third World nations do not have access to the "global" information superhighway because they lack "onramps." Their telecommunications infrastructure is lacking.
6. **Leave No Traces** Don't leave a trail or trace of your presence; don't call attention to yourself or your exploits. Keep quiet, so everyone can enjoy what you have. This is an ethical principle, in that the hacker follows it not only for his own self-interest, but also to protect other hackers from being caught or losing access. Such a principle can be found among various criminal or underground organizations. Of course, there is a contradiction between asserting a need for secrecy (as well as privacy), and the need for unrestricted information.
7. **Share!** Information increases in value by sharing it with the maximum number of people; don't hoard, don't hide. Just because it wants to be free, does not mean necessarily you must give it to as many people as possible. This principle can be seen as an elaboration on an original ethical principle. The Pirates' ethic is that piracy increases interest in software, by giving people a chance to try it out and experiment with it before paying for it. So sharing software with your friends is a good thing.
8. **Self Defense** against a Cyberpunk Future Hacking and viruses are necessary to protect people from a possible 1984/cyberpunk dystopian future, or even in the present from the growing power of government and corporations. It's a moral imperative to use hacking as the equivalent of 'jujitsu,' allowing the individual to overcome larger, more impersonal, more powerful forces that can control their lives. If governments and corporations know they can be hacked, then they will not overstep their power to afflict the citizenry.
9. **Hacking Helps Security** This could be called the "Tiger team ethic": it is useful and courteous to find security holes, and then tell people how to fix them. Hacking is a positive force, because it shows people how to mend weak security, or in some cases to recognize and accept that total security is unattainable, without drastic sacrifice.
10. **Trust, but Test!** You must constantly test the integrity of systems and find ways to improve them. Do not leave their maintenance and schematics to others; understand fully the systems you use or which affect you. If you can exploit certain systems (such as the telephone network) in ways that their creators never intended or anticipated, that's all to the better. This could help them create better systems. One of those systems that may require constant revision, testing, and adjustment, apparently, is constitutional democracy.

So, in short, the new hacker ethic suggests that it is the ethical duty of new hackers (or the CU), to : 1) protect data and hardware 2) respect and protect privacy 3) utilize what is being wasted by others 4) exceed unnecessary restrictions 5) promote peoples' right to communicate 6) leave no traces 7) share data and software 8) be vigilant against cyber-tyranny and 9) test security and system integrity of computer systems.

- **Ethical Hacking vs. Unethical Hacking:** The activity of hacking can be divided into ethical hacking and unethical hacking. We have already discussed a lot about hacking ethics above but how can we distinguish what kind of hacking is ethical and what kind of hacking is unethical? In this section, we will give a brief description of ethical hacking and unethical hacking.

    1. **Ethical Hacking:** Ethical hacking is always carried out by ethical hacker (or the so-called "white hat"). Ethical hackers are a gang of computer security expert who "specializes in penetration testing and in other testing methodologies to ensure the security of an organization's information systems" [10]. These ethical hackers "have the ability to harm your system but they chose to make the choice to help uncover security failings in your system and then help you to find ways to protect your company from other hackers" [11]. For ethical hackers, they will only hack and test on a system when they are authorized by the owner of the system in order to find a security flaws or to detect the cause after an attack. The point here is that ethical hackers always do the hacking work under the permission of the system's owner. They will only hack as deep as the owner of the system specifies. For ethical hacking, it will be helpful to find out the system security holes, potential system vulnerabilities and the fact that whether a system is under attack.

2. **Unethical Hacking:** Unethical hacking is a malicious hacking activity carried out by malicious hacker. Malicious hackers are also a group of computer security experts but their general purpose for hacking is to steal secret information from a system, corrupt a system or leave back doors to a compromised system in order for the future access. For malicious hacking, the hackers are not authorized to access the information that they grab from the system. Malicious hacking may cause unpredictable economical loss to a corporation since the business strategy and product information stolen. So, here is the other point, malicious hackers carry out malicious hacking without the permission and authorization from the owner of the system.

References:

[1]: http://it.med.miami.edu/x904.xml

[2]: http://oxforddictionaries.com/

[3]: http://it.toolbox.com/blogs/security-commonsense/confidentiality-integrity-availability-cia-oh-my-7123

[4]: http://www.ee.oulu.fi/research/ouspg/sage/glossary/

[5]: http://www.articlesbase.com/security-articles/top-10-mobile-application-threats-4053059.html

[6] http://en.wikipedia.org/wiki/Hacker_ethic

[7] www.issa.org/Downloads/ISSA-Ethics-Presentation-20070427.ppt

[8] http://www2.fiu.edu/~mizrachs/hackethic.html

[9] Michael T. Simpson , Kent Backman, James Corley. "Hands-On Ethical Hacking and Network Defense", Delmar Cengage Learning; 2 edition (March 17, 2010)

[10] http://en.wikipedia.org/wiki/White_hat_(computer_security)

[11] http://computers-security.com/153/ethical-hacking-does-such-thing-exist/

Comments

You do not have permission to add comments.

Sign in | Recent Site Activity | Report Abuse | Print Page | Powered By **Google Sites**